

INTERNAL

AI Risk and Impact Assessment Template

Template - issued 15.05.26

Status	Draft
Security	Company Restricted
Version No.	1.0
Approved by	Accountable Owner / Approver
Author(s)	AI Governance Team

Contents

- 1. How to use this template 3
 - 1.1 System Identity.....3
 - 1.2 Summary3
- 2. Stakeholders and Impact Groups (C1).....4
- 3. Risk Tier Classification (C1)5
 - 3.1 Tier Rationale5
 - 3.2 Regulatory Flags.....5
- 4. AI-Specific Risks (C5).....6
- 5. Risk Treatment Plan (C5)7
- 6. Residual Risk Acceptance (C5).....8
- 7. Independent Review (C13)9
- 8. Societal Impact (A.5.5)10
- 9. Foreseeable Misuse Scenarios.....11
- 10. Review Schedule.....12
- 11. Change History13

1. How to use this template

This template captures the Risk and Impact Assessment for an AI system delivered or operated by Kainos. It combines the intended-use impact assessment (C1) and the AI risk assessment and treatment plan (C5). It is one of the four mandatory artefacts.

Complete every section. Tier 3 systems must additionally complete the Independent Review section (C13). Italic guidance text should be removed once the section is completed.

1.1 System Identity

Field	Value
AI System Name	[Enter system name]
OneTrust Assessment	[OneTrust Assessment ID]
Risk Tier	[Tier 2 Medium / Tier 3 High]
Customer (if applicable)	[Enter customer name]
Data Governance Role	[Controller / Joint Controller / Processor]
Data Controller	[If not Kainos]
Monitoring Owner	[Customer / Kainos / Shared]
Accountable Owner	[Name, role]
Approver	[Name, role - for Tier 2/3 not the Owner]
Reviewer(s)	[Security / Data Ethics / QA / Legal as required]
Lifecycle Stage	[Discover / Design / Develop / Deploy & Operate]
Version	[x.y]
Date	[dd.mm.yy]
Status	[Draft / Approved / Superseded]

1.2 Summary

Key points to capture in this artefact:

- The problem the system addresses and why AI is appropriate.
- The people and groups it could affect, including vulnerable groups.
- The agreed risk tier and how it was determined.
- The AI-specific risks, their treatments, and accepted residual risk.
- The approver(s) and the basis for residual risk acceptance.
- The review schedule and triggers for reassessment.

2. Stakeholders and Impact Groups (C1)

Identify the people and groups affected by the system, including any vulnerable groups (children, patients, jobseekers, etc.), and the nature of the impact. ISO/IEC 42005 expects this analysis to inform the risk assessment.

Stakeholder / group	Relationship to system	Potential impact	Vulnerable group?
[Primary users]	[Direct use]	[Benefit / harm / deskillling / over-reliance / confidence]	[Yes / No]
[Data subjects]	[Indirect via data]	[Benefit / harm]	[Yes / No]
[Operators]	[Oversight]	[Workload, accountability]	[No]
[Third parties]	[Affected by outputs]	[Benefit / harm / social and psychological impacts]	[Yes / No]
[Add rows as needed]			

3. Risk Tier Classification (C1)

[Risk tier classification will be determined by outcome of AI Intake Assessment. If you are unsure of the risk tier allocated to the system, please contact the AI Governance forum via AIGovernance@kainos.com]

Tier	Indicative criteria	Selected?
Tier 1 - Low	Internal only; non-decisional; no personal or sensitive data; reversible outputs.	<i>[Yes / No]</i>
Tier 2 - Medium	Customer-facing or decision-support; processes personal or commercially sensitive data.	<i>[Yes / No]</i>
Tier 3 - High	Regulated decision-making, vulnerable users, or EU AI Act Annex III high-risk use.	<i>[Yes / No]</i>

3.1 Tier Rationale

[Record the reasoning for the selected tier, including any specific criteria that triggered Tier 2 or Tier 3.]

3.2 Regulatory Flags

Flag	Applies?	Notes / reference
EU AI Act - High risk (Annex III)	<i>[Yes / No]</i>	<i>[Reasoning, reference]</i>
EU AI Act - Prohibited practice	<i>[Yes / No]</i>	<i>[Reasoning]</i>
UK GDPR / Data Protection Act 2018	<i>[Yes / No]</i>	<i>[DPIA reference]</i>
Sector-specific (e.g. FCA, MHRA)	<i>[Yes / No]</i>	<i>[Authority and obligation]</i>
Other	<i>[Yes / No]</i>	<i>[Detail]</i>

4. AI-Specific Risks (C5)

Identify AI-specific risks that apply to this system. Include classical AI/ML threats and, where applicable, LLM / agentic threats (e.g. prompt injection, tool misuse). Use likelihood/impact scoring consistent with the Kainos risk management approach.

Ref	Risk	Cause / Source	Likelihood	Impact	Inherent rating
R1	[Bias / unfair outcomes]	[Training data, proxy variables]	[L/M/H]	[L/M/H]	[Low/Med/High]
R2	[Accuracy / hallucination]	[Model limitations]	[L/M/H]	[L/M/H]	[L/M/H]
R3	[Privacy / data leakage]	[Logging, prompt exposure]	[L/M/H]	[L/M/H]	[L/M/H]
R4	[Prompt injection / abuse]	[Untrusted inputs]	[L/M/H]	[L/M/H]	[L/M/H]
R5	[Model drift]	[Data distribution change]	[L/M/H]	[L/M/H]	[L/M/H]
R6	[AI supply chain dependency]	[Third-party model, hosting, API change, pricing changes, customer mandated suppliers]	[L/M/H]	[L/M/H]	[L/M/H]
R7	[Operational misuse]	[Use beyond intended scope]	[L/M/H]	[L/M/H]	[L/M/H]
R8	[Human factors - automation bias, over-trust, skill erosion, accountability ambiguity, cognitive overload, stress and anxiety]	[Excessive reliance/ over confidence in outputs]	[L/M/H]	[L/M/H]	[L/M/H]
R9	[Add new rows as needed]				

5. Risk Treatment Plan (C5)

Define the mitigations applied to each risk, the residual rating after mitigation, and the owner of each control. Reference the Monitoring and Review Record for the control effectiveness check.

Ref	Mitigation / control	Owner	Residual rating	Verification (link)
R1	[Bias testing, balanced data, mitigations]	[Owner]	[L/M/H]	[MRR section]
R2	[Guardrails, human review]	[Owner]	[L/M/H]	[MRR section]
R3	[Redaction, encryption, access control]	[Owner]	[L/M/H]	[MRR section]
R4	[Input validation, allow-lists, tool guards]	[Owner]	[L/M/H]	[MRR section]
R5	[Drift monitoring, retraining]	[Owner]	[L/M/H]	[MRR section]
R6	[Supplier assessment, contractual controls]	[Owner]	[L/M/H]	[MRR section]
R7	[User information, oversight, redress]	[Owner]	[L/M/H]	[MRR section]
R8	[User training, decision-support guidance, challenge mechanisms, usability testing]	[Owner]	[L/M/H]	[MRR section]

6. Residual Risk Acceptance (C5)

Record the formal acceptance of residual risk by the Approver. For Tier 2 and Tier 3 systems the Approver must not be the Accountable Owner.

Aspect	Detail
Overall residual risk rating	[Low / Medium / High]
Basis for acceptance	[Why the residual risk is acceptable for the intended use.]
Conditions of acceptance	[Any conditions, restrictions, or monitoring obligations.]
Approver name and role	[Name, role]
Approval date	[dd.mm.yy]
Cross-reference	[Approvals & Exceptions log entry ID]

7. Independent Review (C13)

Tier 3 systems require independent review of this Risk and Impact Assessment by a function outside the delivery team (Data Ethics, Security, or Compliance). For Tier 1 / Tier 2 systems, mark this section as Not Applicable.

Aspect	Detail
Reviewing function	[Data Ethics / Security / Compliance]
Reviewer name	[Name]
Date of review	[dd.mm.yy]
Scope of review	[What was reviewed]
Outcome	[Endorsed / Endorsed with conditions / Not endorsed]
Conditions / actions	[Conditions or required actions]
Re-review date	[dd.mm.yy or trigger]

8. Societal Impact (A.5.5)

For Tier 2 and Tier 3 systems, record impacts that reach beyond direct users. Each dimension below should be assessed; mark "Not material" with brief justification if it does not apply.

Dimension	Considerations	Assessment for this system	Mitigations / monitoring
Environmental footprint	Compute, energy, water use of training and serving; choice of region; use of efficient or shared infrastructure.	[Estimate; e.g. shared LLM tenancy, region with low-carbon grid, no bespoke training]	[e.g. prefer shared endpoints; cap retraining frequency]
Labour-market / workforce	Roles automated or augmented; reskilling implications; change-management for affected staff.	[Which roles are affected? Internal Kainos staff or end-customer workforce?]	[e.g. role redesign plan; training; communications]
Public-interest / vulnerable groups	Outputs reaching citizens, vulnerable populations, regulated entities, or democratic processes.	[Public-facing? Vulnerable users? Public-sector deployment?]	[e.g. additional human review; accessibility; redress route]
Concentration / vendor dependency	Reliance on a single third-party model, vendor, or region; exit options; supplier lock-in.	[Single LLM vendor? Available alternates? Exit complexity?]	[e.g. abstraction layer; documented exit path; multi-model evaluation]
Social exclusion	Consider accessibility needs, digital exclusion, language barriers, performance disparities for low-resource languages, regional dialects, cultural nuances, and the availability of alternative channels and reasonable adjustments.	[Could any groups face barriers to access, participation, or service quality due to digital exclusion, accessibility needs, language, literacy, culture, or preference for non-AI interactions? Does the system perform consistently across supported languages and user groups? Are non-AI channels available?]	[e.g. maintain human-assisted alternatives; accessibility testing; multilingual evaluation; testing across dialects and non-native speaker populations; monitor complaints and performance disparities by user group; provide reasonable adjustments and support channels]

9. Foreseeable Misuse Scenarios

List the realistic ways the system could be misused, whether intentionally (prompt injection, jailbreaks, data exfiltration, agent tool abuse) or unintentionally (use outside intended scope, copy-paste of confidential data into external models, blind acceptance of outputs). For each scenario record the likelihood, the harm, and the controls that prevent or detect it. Cross-reference the corresponding risk row in the AI-Specific Risks table where applicable.

Ref	Misuse scenario	Likelihood	Harm	Preventive / detective control
M1	[Prompt injection via untrusted retrieved content]	[L/M/H]	[Disclosure / wrong action]	[Input validation, allow-listed tools, system prompt hardening]
M2	[User pastes confidential client data into prompt]	[L/M/H]	[Data leakage]	[DLP, in-product notice, redaction]
M3	[Use of outputs beyond intended scope]	[L/M/H]	[Wrong decision]	[Operator runbook, user information, audit sampling]
M4	[Agent tool abuse / unintended side effects]	[L/M/H]	[Operational / financial]	[Action allow-list, human-in-the-loop for write actions]
M5	[Add rows as needed]			

10. Review Schedule

State when this assessment will be reviewed. Reviews are mandatory on material change (data, model, intended use, supplier), at annual intervals at minimum, and after any AI incident.

Trigger	Cadence / criterion
Time-based review	[At minimum annually; or cadence appropriate to tier]
Material change review	[Model change, data change, scope change, supplier change]
Incident-driven review	[After any AI incident or near-miss]
Regulatory change	[Trigger conditions]

11. Change History

Version	Date	Author	Change
[1.0]	[dd.mm.yy]	[Name]	[Initial issue.]
[]	[]	[]	[]

kainos®

